ENTREGA DEL LABORATORIO

Qué necesita cada estudiante

ENTORNO

Kali Linux (VM o live USB). **John** y **Hashcat** vienen preinstalados.

Diccionario: descomprimir *rockyou.txt*.

```
$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz
```

ARCHIVOS RECIBIDOS

secreto.zip — para el Reto 1

h2.txt + la regla de política — para el Reto 2

guia_estudiante.pdf — planteamiento y consejos, sin respuestas

RETO 1 · PRINCIPIANTE

Extraer y romper un hash con John the Ripper

PLANTEAMIENTO

Se entrega **secreto.zip**, un archivo comprimido protegido con contraseña. El objetivo es extraer el hash que contiene y recuperar la contraseña original.

CONSEJOS

1. Las utilidades **2john* (zip2john, rar2john...) convierten archivos protegidos a un formato que John puede leer.

2. John detecta el tipo de hash automáticamente: no hace falta indicarlo.

3. Prueba primero con el diccionario *rockyou.txt*: cubre la mayoría de contraseñas comunes.

RETO 1 · SOLUCIÓN

Comandos y explicación

```
// extraer el hash del .zip
$ zip2john secreto.zip > hash.txt

// romperlo con el diccionario
$ john hash.txt
$ john --show hash.txt
```

EXPLICACIÓN

zip2john lee la cabecera del .zip y escribe su hash en el formato que John entiende.

John prueba cada palabra de *rockyou.txt*, la hashea y la compara: al ser una clave común, la encuentra en segundos.

RESPUESTA Panda123

RETO 2 · INTERMEDIO

Ataque de máscara en Hashcat, sin diccionario

PLANTEAMIENTO

La empresa exige contraseñas con el patrón **1 mayúscula + 5 minúsculas + 2 dígitos**. Se entrega **h2.txt**, el hash de una clave que cumple esa política. Encuéntrala sin usar diccionario.

CONSEJOS

1. Traduce la política a una máscara: **?u?l?l?l?l?l?d?d** (mayúscula, 5 minúsculas, 2 dígitos).

2. Usa **-a 3** (máscara) y revisa con **--help** qué **-m** corresponde al hash.

3. Conocer la política reduce el espacio de búsqueda frente a una fuerza bruta genérica.

RETO 2 · SOLUCIÓN

Comando y explicación

```
// ataque de máscara, sin diccionario
$ hashcat -m 1800 -a 3 \
  h2.txt ?u?l?l?l?l?d?d
```

?u mayúscula · ?l minúscula · ?d dígito

EXPLICACIÓN

Hashcat genera en la GPU solo las combinaciones que calzan con la máscara: $26 \times 26^5 \times 10^2$ posibilidades, muchas menos que una fuerza bruta sin restricciones.

Por eso una política "fuerte" pero predecible se rompe rápido si el atacante la conoce.

RESPUESTA Zebras42